University Digital Library Management System

Owner: NetroHawks
Reviewer: Mam Muneeba
Contributors: Muhammad Hammad, Ali Hamza, Saim Ali Shahid
Date Generated: Tue Oct 27 2026

Executive Summary

High level system description

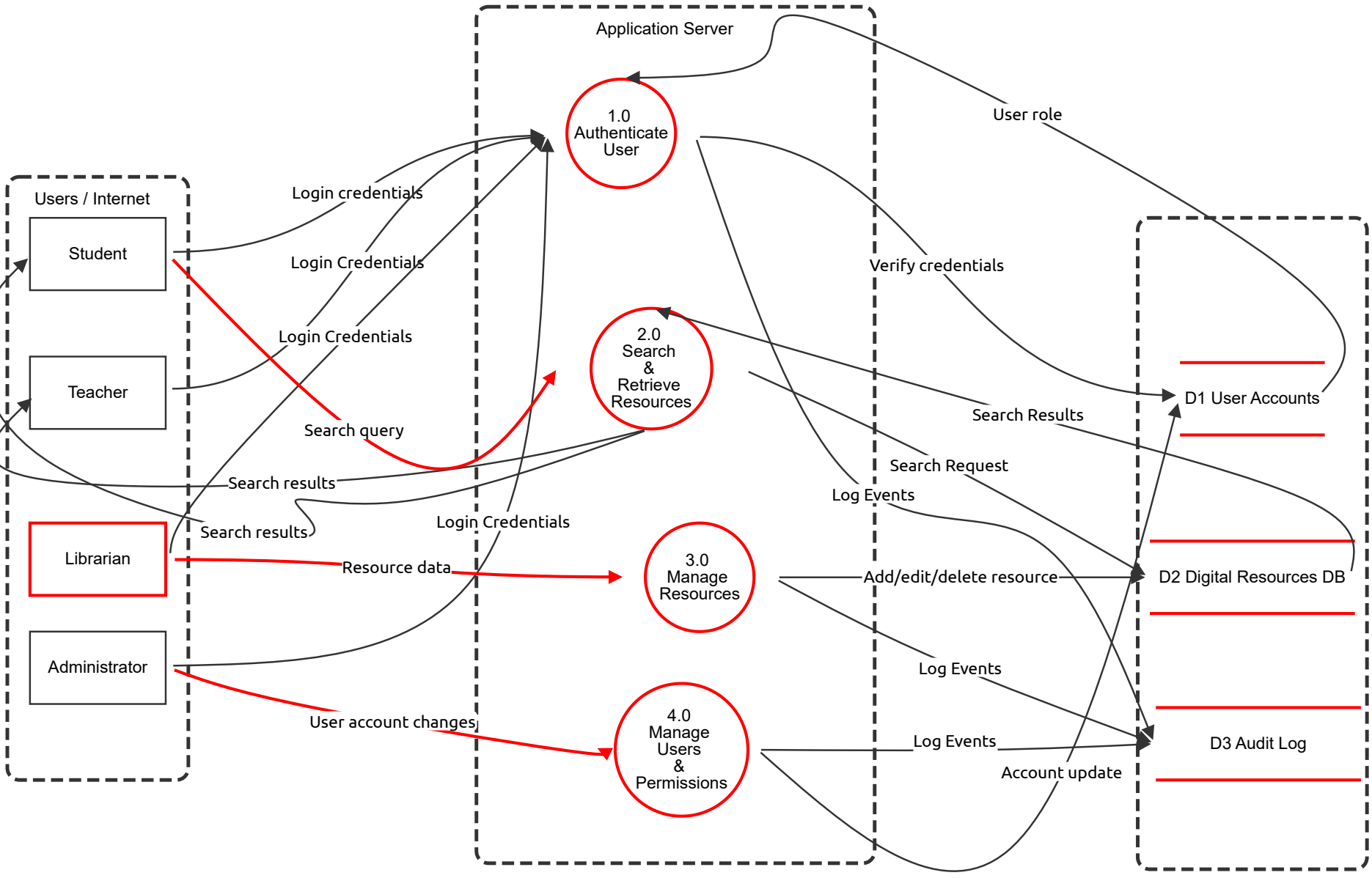
The University Digital Library is a web app where students and teachers search and download digital books and papers, librarians manage the content, and admins control accounts and permissions. It uses a cloud database and requires login for all users. The aim is secure, role-based access with no unauthorized access, tampering, or service disruption.

Summary

Total Threats	12
Total Mitigated	0
Total Open	12
Open / Critical Severity	0
Open / High Severity	8
Open / Medium Severity	3
Open / Low Severity	1

New STRIDE diagram

Level-1 DFD for University Digital Library showing actors, processes, data stores, and trust boundaries.



New STRIDE diagram

Student (Actor)

Description: Searches, views, and downloads library resources. Read-only access.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Teacher (Actor)

Description: Searches, views, and downloads resources. Same as student but may access licensed content.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Administrator (Actor)

Description: Creates, updates, deletes user accounts and assigns roles. Highest privilege.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Librarian (Actor)

Description: Adds, edits, and removes books/papers. Write access to resource database.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
7	Stolen session token used to upload fake resources.	Spoofing	High	Open	12	An attacker steals a Librarian's active session cookie via cross-site scripting (XSS). They use the stolen session to upload malicious PDF files to the library without needing the Librarian's password.	Implement short session timeouts, use HttpOnly and Secure flags on cookies, and enforce re-authentication for upload actions.

1.0 Authenticate User (Process)

Description: Verifies username/password against User Accounts DB and assigns role. Handles credentials

Number	Title	Type	Severity	Status	Score	Description	Mitigations
1	Attacker guesses a Teacher's password	Spoofing	High	Open	20	An external attacker uses an automated brute-force tool against the login process. Because there is no limit on failed attempts, they eventually guess a teacher's password and gain unauthorized access to download restricted academic papers.	Lock the account after 5 failed attempts, enforce rate limiting, and require 12-character passwords with MFA for teachers.

2.0 Search & Retrieve Resources (Process)

Description: Handles search queries and returns matching books/papers from resources DB.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
5	Botnet floods the search function	Denial of service	High	Open	16	An attacker uses a botnet to send thousands of automated search queries per second to Process 2.0. The application server becomes overloaded and crashes, preventing legitimate students from searching for resources.	Implement a Web Application Firewall (WAF) and API rate limiting to block high-volume traffic from single IP addresses.

3.0 Manage Resources (Process)

Description: Librarian adds, edits, or deletes books and papers in the resources DB.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
3	Librarian denies deleting a critical resource	Repudiation	Medium	Open	8	A librarian deletes an important digital resource from the library. Later, they claim they never did it. Because the system lacks a proper audit trail linking actions to specific user IDs, the university cannot prove who performed the deletion.	Ensure Process 3.0 sends a "Log Event" to D3 Audit Log containing the user ID, timestamp, and action performed.

4.0 Manage Users & Permissions (Process)

Description: Admin creates, updates, deletes user accounts and changes roles. Handles credentials Handles PII

Number	Title	Type	Severity	Status	Score	Description	Mitigations
6	Student manipulates account changes to gain Admin rights	Elevation of privilege	High	Open	20	A student intercepts the "User account changes" data flow and modifies the request to change their own role from 'Student' to 'Administrator'. The server processes the request without checking if the requester has the authority to make that change.	Implement strict server-side Role-Based Access Control (RBAC). Verify that the user making the request is an Admin before applying account updates.

D1 User Accounts (Store)

Description: Stores usernames, hashed passwords, roles, and personal details.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
8	Direct database modification of user roles	Tampering	Medium	Open	8	An attacker gains direct access to the D1 User Accounts database (e.g., via a misconfigured cloud port) and manually updates their account row to change their role to Administrator.	Restrict database access to only the application server's IP address, use strong database passwords, and encrypt the database at rest.
10	Login floods lock up the user database	Denial of service	Medium	Open	9	An attacker sends thousands of concurrent login requests to Process 1.0. This causes Process 1.0 to open too many connections to D1 User Accounts, causing the database to crash and preventing all users from logging in.	Implement database connection pooling limits and configure rate limiting on the authentication endpoint.

D2 Digital Resources DB (Store)

Description: Stores book/paper metadata, file paths, and resource records.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
4	Unencrypted database backup exposed	Information disclosure	High	Open	15	An attacker gains access to the cloud storage where the Digital Resources DB is backed up. Because the backup is stored in plain text, the attacker downloads all copyrighted materials and restricted research papers.	Encrypt the database at rest and enforce strict access controls on cloud storage buckets.

Login credentials (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Login Credentials (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Login Credentials (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Verify credentials (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

User role (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Add/edit/delete resource (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Account update (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Search results (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Search results (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Login Credentials (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Log Events (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Search Request (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Log Events (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Log Events (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Search Results (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

User account changes (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
13	Attacker alters account permissions in transit	Tampering	High	Open	15	An attacker intercepts the "User account changes" data flow using a Man-in-the-Middle attack. They modify the request payload to change a user's role from 'Student' to 'Administrator' before it reaches Process 4.0, granting them full control over the system.	Encrypt all internal data flows using TLS 1.3 to prevent interception, and implement server-side checksum validation to detect tampered payloads.

Search query (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
14	SQL injection in the search query (Critical)	Tampering	High	Open	25	A student enters malicious SQL code (e.g., ' OR 1=1 --) into the search query field. The application passes this input directly to D2 Digital Resources DB, allowing the attacker to dump the entire database.	Use parameterized queries (prepared statements) for all database interactions and implement strict input validation.

Resource data (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
2	Malicious file intercepted and altered in transit	Tampering	High	Open	16	A Man-in-the-Middle attacker intercepts the "Resource data" flow between the Librarian and Process 3.0. They alter the PDF file before it reaches the database, corrupting the integrity of the digital resource.	Enforce TLS 1.3 encryption for all data in transit and use file hashing to verify integrity upon receipt.

D3 Audit Log (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
9	Unauthorized reading of audit logs	Information disclosure	Low	Open	4	A curious student discovers that the D3 Audit Log is publicly accessible and reads the login history and IP addresses of other students and teachers.	Configure the audit log database with strict read-access controls so only the system administrator can view it.